

Principles of Border Security

Your network and the Internet both utilize TCP/IP as a connection methodology, and since you have at least some valid Internet addresses, your network is technically just part of the larger Internet. From a security standpoint, “your” network is actually defined as that place where you begin to enforce rules about how the network will be used. Outside those borders, it’s no-man’s land.

Like nations, you could simply have open borders and enforce security within every city. This would be analogous to having servers and clients placed directly on the Internet and requiring them to each handle their own security. This is exactly how the Internet worked originally. Prior to 1990, there were so few hacking attempts (CERT listed only six for 1988) that serious attempts at security would have been an unnecessary distraction.

TIP

This chapter serves as an introduction to border security. Border security is a vast topic that would easily fill a book. I recommend mine: *Firewalls 24seven, 2nd Ed.* (Sybex, 2002).

But today, enforcing security at every machine within your network would put a serious burden on your users and staff, and you would have no control over the use of bandwidth within your network—hacking attempts could reach inside your network and propagate there. (Universities began having this problem in the early nineties as students began setting up their own web servers, which suddenly became popular and begin consuming tremendous bandwidth.)

Border security theory requires these measures:

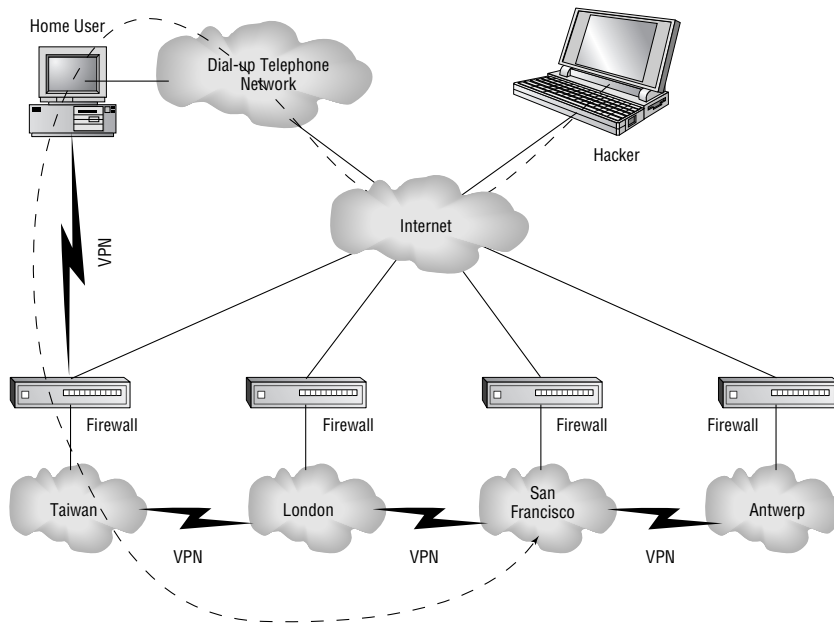
demilitarized zone

A security zone with a separate, more relaxed security policy that is used to partition public servers like e-mail and web servers away from the internal network while providing them firewall protection.

Control every crossing. You can control all the data flowing between your network and the Internet by placing firewalls at every connection to your network. In this case, “every crossing” literally means every connection. Controlling every possible connection to the Internet is the most important measure you can take to control security on your network. A single connection into your network that isn’t monitored by firewalls could allow an intrusion. Like a leaking dam, your security policy means nothing if it is not universally enforced. This means that wireless network access points, modems, and any other method of transmitting data must be taken into account (eliminated or firewalled) in order to truly secure your network.

Apply the same policy universally. If you want to control a specific type of traffic, you have to control it the same way at every crossing because the net effect of your security policy is equal to the loosest policy on any single firewall; if you allow a protocol to pass on one firewall, you’re allowing that protocol in, so blocking it on another firewall is essentially pointless.

If you need two different levels of security for different purposes, put a firewall behind the machines that require expanded Internet access so that if they are breached, the remainder of your network is still firewalled. This



configuration is called a *demilitarized zone* (DMZ). A DMZ is simply a separate interface to which you can apply a separate and more relaxed firewall policy.

Enterprise-level firewalls, like Check Point FireWall-1, allow you to create a single policy and then apply it to all firewalls. Most other firewalls require vigilance on the part of security administrators to ensure that their policies are uniform across their pool of firewalls.

Deny by default. Early firewalls allowed all Internet traffic except that which was specifically blocked. This didn't work for long. To be secure, you must deny all traffic except that which you specifically want to allow. This is important for both incoming and outgoing data. The effect of accidentally downloading a Trojan horse is mitigated if the Trojan horse can't open an outgoing connection through your firewall.

Hide as much information as possible. Firewalls should not reveal anything about the nature of the interior of the network—in fact, they shouldn't reveal their own existence, if possible. When hackers scan for networks using Ping scanners, they rely upon the victim to respond. No response means no victim, so your firewalls should be configured to hide their presence by not responding to these sorts of scans. This also means that technologies like Simple Network Management Protocol (SNMP) should not be used to manage firewalls from the public side and that the administrator should be able to reach the firewall only from the private interface.

firewall

A gateway that connects a private network to a public network and enforces a security policy by allowing only those connections that match the device's security settings.

border gateway

A firewall.

Understanding Firewalls

Firewalls keep your Internet connection as secure as possible by inspecting and then approving or rejecting each connection attempt made between your internal network and external networks like the Internet. Strong firewalls protect your network at all software layers—from the Data link (such as Ethernet) layer up through the Network layer (such as TCP/IP) and up to the Application layer (such as HTTP).

Firewalls sit on the borders of your network, connected directly to the circuits that provide access to other networks. For that reason, firewalls are frequently referred to as border security. The concept of border security is important—without it, every host on your network would have to perform the functions of a firewall itself, needlessly consuming computing resources and increasing the amount of time required to connect, authenticate, and encrypt data in local area, high-speed networks. Firewalls allow you to centralize all network security services in machines that are optimized for and dedicated to the task. Inspecting traffic at the *border gateways* also has the benefit of preventing hacking traffic from consuming the bandwidth on your internal network.

By their nature, firewalls create bottlenecks between the internal and external networks because all traffic transiting between the internal network and the external must pass through a single point of control. This is a small price to pay for security. Since external leased-line connections are relatively slow compared to the speed of modern computers, the latency caused by firewalls can be completely transparent. For most users, relatively inexpensive firewall devices are more than sufficient to keep up with a standard T1 connection to the Internet. For businesses and ISPs whose Internet traffic is far higher, a new breed of extremely high-speed (and high-cost) firewalls has been developed that can keep up with even the most demanding private networks. Some countries actually censor the entire Internet using high-speed firewalls.

Fundamental Firewall Functions

There are three basic functions that modern firewalls perform:

- ◆ Packet filtering
- ◆ Network Address Translation
- ◆ Proxy service

Nearly all firewalls use these basic methods to provide a security service. There are literally hundreds of firewall products on the market now, all vying for your security dollar. Most are very strong products that vary only in superficial details.

You could use devices or servers that perform only one of these functions; for instance, you could have a router that performs packet filtering and then have a *proxy server* in a separate machine. That way, either the packet filter must pass traffic through to the proxy server or the proxy server must sit outside your network without the protection of packet filtering. Both scenarios are more dangerous than using a single firewall product that performs all the security functions in one place.

Many strong firewalls do not actually perform proxy services, but the strongest firewalls do. Proxy services strengthen the security of a firewall by inspecting information at the Application layer—however, very few firewalls actually proxy any protocols other than HTTP and SMTP.

Packet Filtering

Packet filters implemented inside firewalls prevent suspicious traffic from reaching the destination network. Filtered routers protect all the machines on the destination network from suspicious traffic. Filters typically follow these rules:

- ◆ Dropping inbound connection attempts but allowing outbound connection attempts to pass.
- ◆ Eliminating TCP packets bound for ports that shouldn't be available to the Internet (such as the NetBIOS session port) but allowing packets that are required (such as SMTP) to pass. Most filters can specify exactly which server a specific sort of traffic should go to—for instance, SMTP traffic on port 25 should only go to the IP address of a mail server.
- ◆ Restricting inbound access to internal IP ranges.

Sophisticated filters examine the states of all connections that flow through them, looking for the telltale signs of hacking, such as *source routing*, ICMP redirection, and IP spoofing. Connections that exhibit these characteristics are dropped.

Internal clients are generally allowed to create connections to outside hosts, and external hosts are usually prevented from initiating connection attempts. When an internal host decides to initiate a TCP connection, it sends a TCP message to the IP address and port number of the public server (for example, `www.microsoft.com:80` to connect to Microsoft's website). In the connection initiation message, it tells the remote server what its IP address is and on which port it is listening for a response (for example, `192.168.212.35:2050`).

proxy server

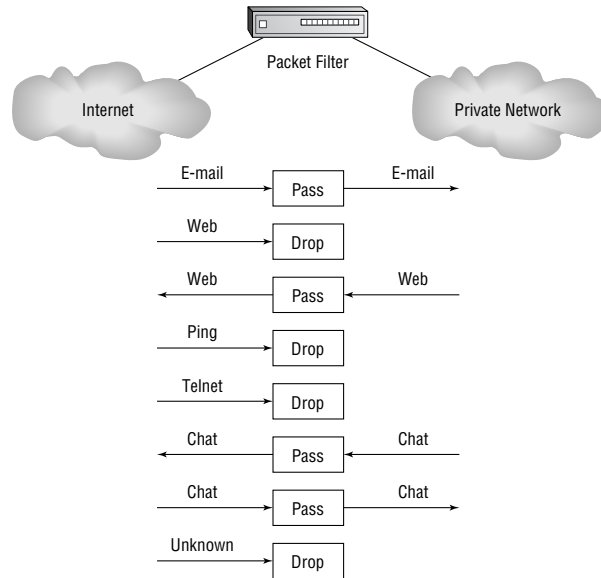
A server that hosts application proxies.

packet filter

A router that is capable of dropping packets that don't meet security requirements.

source routing

An often-abused TCP/IP troubleshooting mechanism that allows the sender of a packet to define a list of routers through which the packet must flow.

**stateless packet filters**

Packet filters that make pass/reject decisions based only on the information contained in each individual packet.

stateful inspection

A packet-filtering methodology that retains the state of a TCP connection and can pass or reject packets based on that state rather than simply on information contained in the packet.

circuit-layer switch

A TCP proxy service.

There are three primary types of Network layer firewalls:

- ◆ *Stateless packet filters*, which do not maintain the state of connections and make pass/drop decisions based purely upon information contained within each individual packet. Stateless packet filters are obsolete unless used along with NAT or proxy services, because they cannot block the complete range of threatening data.
- ◆ *Stateful inspection* packet filters, which maintain tables of information about the connections flowing through them. They can pass or drop packets based on information contained in earlier packets in a connection stream.
- ◆ *Circuit-layer switches* (also called TCP proxy servers) terminate a TCP connection on one interface and regenerate it on the other. This allows the interior network to be hidden from the external network (similar to the way a network address translator works) and also completely regenerates the TCP/IP packets, so malformed packets are not passed through. Circuit-layer switches break the routed connection between networks, but they are not specific to higher-level protocols the way application proxies are.

All modern firewalls are either stateful inspectors or circuit-layer switches. Since your firewall inspects all the traffic exchanged between both hosts, it knows that the connection was initiated by an internal host attached to its internal interface, what that host's IP address is, and which port that host expects to receive return traffic on. The firewall then remembers to allow the host addressed in the connection message to return traffic to the internal host's IP address only at the port specified.

When the hosts involved in the connection close down the TCP connection, the firewall removes the entry in its state table (its connection memory) that allows the remote host to return traffic to the internal host. If the internal host stops responding before closing the TCP connection (because, for example, it has crashed) or if the protocol in question does not support sessions (for example, UDP), then the firewall will remove the entry in its state table after a programmed time-out of usually a few minutes.

Filtering does not completely solve the Internet security problem. First, the IP addresses of computers inside the filter are present in outbound traffic, which makes it somewhat easy to determine the type and number of Internet hosts inside a filter and to target attacks against those addresses. Filtering does not hide the identity of hosts behind the filter (but circuit layer switches do).

Filters cannot check all the fragments of an IP message based on higher-level protocols like TCP headers because the header exists only in the first fragment. Subsequent fragments have no TCP header information and can only be compared to IP level rules, which are usually relaxed to allow some traffic through the filter. This allows bugs in the destination IP stacks of computers on the network to be exploited and could allow communications with a Trojan horse installed inside the network.

Finally, filters are not complex enough to check the legitimacy of the protocols inside the Network-layer packets. For example, filters don't inspect the HTTP data contained in TCP packets to determine if it contains data that exploits the web browser or web server on your end of the connection. Most modern hacking attempts are based upon exploiting higher-level services because firewalls have nearly eliminated successful Network-layer hacking (beyond the nuisance of denial of service attacks).

Network Address Translation (NAT)

Network Address Translation allows you to multiplex a single public IP address across an entire network. Many small companies rely upon the services of an upstream Internet service provider that may be reluctant to provide large blocks of addresses because their own range is relatively restricted. You may want to share a single dial-up or cable modem address without telling your ISP. These options are all possible using Network Address Translation.

The difference between NAT and circuit layer switching is somewhat esoteric: They both achieve nearly the same effect. The difference is that NAT merely rewrites the addresses of packets that otherwise flow through the device without changing the rest of the header, whereas circuit layer switches terminate the external TCP connection and generate an entirely new TCP (or UDP) connection on the private side, passing the data inside the TCP/IP packets from the external to the internal interface. The difference is in the complete regeneration of the TCP/IP packets. However, because circuit layer switches take

Network Address Translation (NAT)

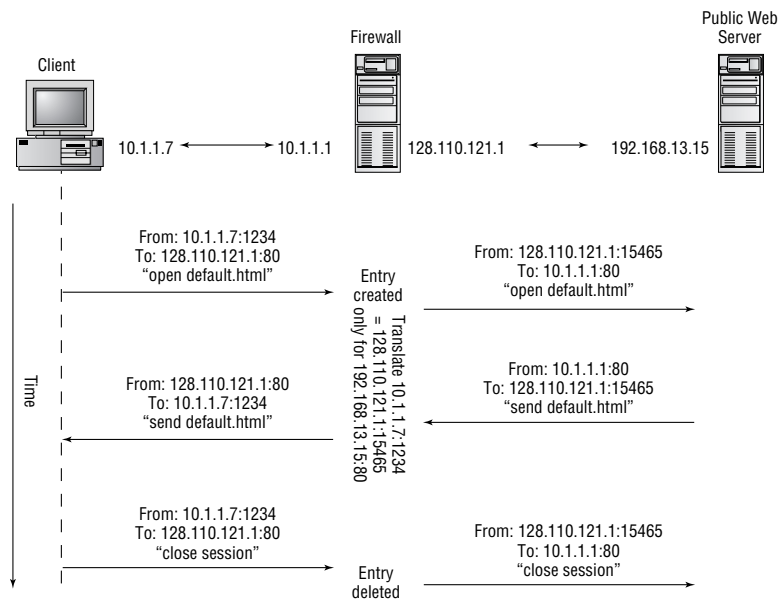
The process of rewriting the IP addresses of a packet stream as it flows through a router for the purpose of multiplexing a single IP address across a network of interior computers and for hiding internal hosts.

considerably more resources to perform what is nearly the same function, NAT devices have become more popular. Circuit layer switches remain more secure, however, because they block malformed packet attacks that might flow through a NAT and they are immune to source routed attacks that can flow right through NATs that do not check for them specifically.

NAT was originally developed because it was difficult to get large blocks of public IP addresses and networks frequently ran out of their assigned pool before they could request more addresses from InterNIC. InterNIC began conserving addresses when the Internet boom began because the pool of available addresses was quickly running out. By multiplexing a single public address to numerous interior hosts in a private IP range, a company could get by with as little as one single public IP address.

Fortuitously, Network Address Translation also solves the problem of hiding internal hosts. NAT is actually a Network-layer proxy: On the Internet, it appears as if a single host makes requests on behalf of all internal hosts, thus hiding their identity from the public network.

NAT hides internal IP addresses by converting all internal host addresses to the public address of the firewall. The firewall then translates the address of the internal host from its own address, using the TCP port number to keep track of which connections on the public side map to which hosts on the private side. To the Internet, all the traffic on your network appears to be coming from one extremely busy computer.



NAT effectively hides all TCP/IP-level information about your internal hosts from prying eyes on the Internet. Address translation also allows you to use any IP address range you want on your internal network, even if those addresses are already in use elsewhere on the Internet. This means you don't have to register a large block of addresses from InterNIC or reassign network numbers you were using before you connected your network to the Internet.

On the down side, NAT is implemented only at the TCP/IP level. This means that information hidden in the data payload of TCP/IP traffic could be transmitted to a higher-level service and used to exploit weaknesses in higher-level traffic or to communicate with a Trojan horse. You'll still have to use a higher-level service like a proxy to prevent higher-level service security breaches.

Finally, many protocols also include the host's IP address in the data payload, so when the address is rewritten while passing through NAT, the address in the payload becomes invalid. This occurs with active-mode FTP, H.323, IPSec, and nearly every other protocol that relies upon establishing a secondary communication stream between the client and the server. It is also not possible to connect to a host inside the private network because there is no way to address hosts directly from the Internet. Most NAT implementations work around this problem for these protocols by "holding open the door" for the return path of protocols that they know will be coming back, like FTP. Because the host connection went out through the translator, it knows to expect a return connection attempt from these protocols and it knows which interior computer to translate the return channel for. So as long as a NAT device is "aware" of these problem protocols, it can handle them. New protocols or applications can often be problematic to implement through NAT devices for this reason.

Using an obsolete troubleshooting feature of TCP/IP called "source routing," where a list of IP addresses that determines the route it should take are provided with a packet, it's possible to connect directly through many early NAT implementations. If you are using NAT for security, make sure that the NAT device drops source-routed packets.

WARNING

NAT is also a problem for network administrators who may want to connect to clients behind the NAT server for administrative purposes. Because the NAT server has only one IP address, there's no way to specify which internal client you want to reach. This keeps hackers from connecting to internal clients, but it also keeps legitimate users at bay as well. Fortunately, most modern NAT implementations allow you to create port-forwarding rules that allow internal hosts to be reached.

Windows 2000 and XP, Linux, and many modern Unix operating systems provide this function as part of the operating system distribution. Windows NT does not.

NOTE

Proxy Services

NAT solves many of the problems associated with direct Internet connections, but it still doesn't completely restrict the flow of packets through your firewall. It's possible for someone with a network monitor to watch traffic coming out of your firewall and determine that the firewall is translating addresses for other machines. It is then possible for a hacker to hijack TCP connections or to spoof connections back through the firewall.

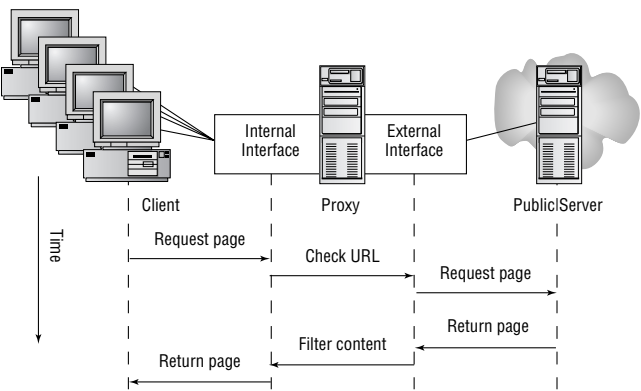
Application-layer proxy
A service for a specific application-layer protocol like HTTP or SMTP that makes connections to the public Internet on behalf of internal private clients. Because application-layer proxies understand the specific protocol for which they proxy, they are able to detect and block malformed or maliciously modified streams.

Application-layer proxies prevent this. Application-layer proxies allow you to completely disconnect the flow of Network-layer protocols through your firewall and restrict traffic only to higher-level protocols like HTTP (for web service), FTP (for downloads), and SMTP (for e-mail). When a connection is made through a proxy server, the proxy server receives the connection, extracts the high-level protocol (like HTTP), examines it, and makes decisions on its content based on its security policy. The proxy server then creates a new TCP connection on the public interface to the ultimate destination and sends the high-level protocol out through the new connection. Because both the Application-layer and Network-layer protocols are completely regenerated, attacks that rely upon malformed TCP/IP packets or malformed web or e-mail messages are eliminated.

Proxies straddle two networks that are not connected by routers. When a client on the protected network makes a connection to a server on the public side, the proxy receives the connection request and then makes the connection on behalf of the protected client. The proxy then forwards the response from the public server on to the internal network. The following graphic shows this process in detail.

NOTE

Proxies are a good example of how an intermediate system between you and another end system could potentially perform any sort of processing—with or without your permission. A rogue proxy hidden between a client and a server would be performing a man-in-the-middle attack.



Application proxies (like Microsoft Internet Security and Acceleration Server) are unlike network address translators and filters in that the Internet client application is (usually) set up to talk to the proxy. For instance, you tell Internet Explorer the address of your web proxy and Internet Explorer sends all web requests to that server rather than resolving the IP address and establishing a connection directly. Most modern firewalls support transparent proxying, where they appear to be routers but actually perform Application-layer protocol proxying rather than forwarding packets.

Application proxies don't have to run on firewalls; any server can perform the role of a proxy, either inside or outside of your network. Without a firewall, you still don't have any real security, so you need both. At least some sort of packet filter must be in place to protect the proxy server from Network-layer denial of service attacks (like the infamous Ping of Death). And, if the proxy doesn't run on the firewall, you'll have to open a channel through your firewall in one way or another. Ideally, your firewall should perform the proxy function. This keeps packets from the public side from being forwarded through your firewall.

Some firewall proxies are more sophisticated than others. Because they have the functionality of an IP filter and network address translator, they can simply block outbound connection attempts (on port 80 in the case of HTTP) to remote hosts rather than having the client software configured to address the proxy service specifically. The firewall proxy then connects to the remote server and requests data on behalf of the blocked client. The retrieved data is returned to the requesting client using the firewall's NAT functionality, appearing as if no filtering had occurred. Proxies that operate in this manner are said to be *transparent*.

transparent

A proxy server that is capable of automatically proxying a protocol without the client's awareness.

Security proxies are even capable of performing Application-level filtering for specific content. For instance, some firewall HTTP proxies look for tags in HTML pages that refer to Java or ActiveX embedded applets and then strip them out. This prevents the applet from executing on your client computers and eliminates the risk that a user will accidentally download a Trojan horse. This sort of filtering is extremely important because filtering, proxying, and masquerading can't prevent your network from being compromised if your users are lured into downloading a Trojan horse embedded in an ActiveX applet.

You may have noticed that as we've climbed through the networking layers, the security services have gotten more specific. For instance, filtering is specific to IP and then to TCP and UDP. Applications that use IP with other unusual protocols like Banyan Vines must use special high-cost or unusually robust firewalls.

Proxies are extremely specific because they can only work for a specific application. For instance, you must have a proxy software module for HTTP, another proxy module for FTP, and another module for Telnet. As these protocols evolve (HTTP is particularly fast moving), the proxy modules will have to be updated.

Many protocols exist that are either proprietary or rare enough that no security proxies exist. Proxies don't exist for proprietary application protocols like Lotus Notes, so those protocols must either be sent through a Network-layer filter or proxied by a generic TCP proxy that regenerates the packet and simply

transfers the payload. SOCKS is a specific form of generic proxy that is sometimes called a circuit-level gateway. Although generic proxying cannot prevent attacks from the content of a protocol, it is still more secure than filtered routing because the Network-layer packets are completely regenerated and thus scrubbed of malformations that might not be detected by the firewall.

Whenever possible, use proxy servers for all application protocols. Consider disallowing application protocols for which you do not have proxy servers. Use high-level proxies capable of stripping executable content like ActiveX and Java from web pages.

Firewall Privacy Services

Firewall Privacy Services are used to allow appropriate connections through the firewall, either from remote users or from firewalls at other sites belonging to the same company. These services are as follows:

- ◆ Encrypted authentication
- ◆ Virtual private networking

With many firewalls, these services are extra-cost options that must be enabled, but some manufacturers include them at no additional cost. As with basic firewalling functions, these services could be performed by other devices on your network, but they are more secure when combined into a border router.

You don't have to incorporate these functions on your firewall—you could use a VPN device and a firewall in parallel, each performing its separate function. But then you have a situation in which the VPN device itself is not firewalled and could be exploited (this was a serious problem with a widely deployed brand of VPN device) and extra routers are required to properly route outbound traffic through either the VPN or the firewall. By combining VPN and firewall functions on a single device, these problems are eliminated.

Authentication

Authentication allows users on the public network to prove their identity to the firewall in order to gain access to the private network.

Essentially, authentication allows users to “log in” to the firewall itself, which will then allow the sessions from their computer to pass through it. For example, you might use this feature to allow remote salespeople to log into their e-mail accounts. Rather than leaving the IMAP, POP3, or MAPI ports open to the public, the firewall will only open these ports to those IP addresses that have successfully passed an authentication challenge. This keeps hackers from trying to run attacks against those ports, and you're not relying solely on the often-insecure login features of the application itself.

Often, authentication is combined with a VPN, but there's nothing that inherently restricts encrypted authentication from working alone.

Virtual Private Networks

Virtual private networking (also called secure *tunneling*) establishes a secure connection between two private networks over a public medium like the Internet. This allows physically separated networks to use the Internet rather than leased-line connections to communicate as though they were directly connected. VPNs are also called encrypted tunnels.

VPNs are extremely important to TCP/IP security and are the exclusive topic of Chapter 6.

virtual private network

An encrypted tunnel.

Other Border Services

While not specifically related to TCP/IP security, the following security-related services are easily performed on border firewalls:

- ◆ Virus scanning
- ◆ Content filtering

There's no limit to the number of services that could be performed on a border firewall—but increasing the amount of software on any computing device increases the odds that a bug will make the software vulnerable to attack. For that reason, firewalls should only run software that is required to enact your security policy.

virus scanning

Searching a file or communication stream for the identifying signature of a virus. A virus signature is simply a series of bytes that is deemed to be unique to the virus.

Virus Scanning

Virus scanning means searching inbound data streams for the signatures of viruses. Keeping up with current virus signatures requires a subscription to the virus update service provided by the firewall vendor.

Chapter 8 discusses virus scanning options in detail.

NOTE

Content Blocking

Content blocking allows you to block internal users from accessing certain types of content by category, such as pornography, websites relating to hate groups, pornography, hacking sites, and pornography. Keeping up with the current list of blocked sites for a specific category also requires a subscription.

In my experience, content blocking doesn't work. There are so many new sites of these types cropping up that blocking vendors can't keep track of them. Users often feel as if any site that isn't blocked is fair game, so content filtering frequently turns into a childish game of escalation between users and the IT staff. For example, you can't keep legitimate web users from using Google, but its Google Images search feature could easily be used to browse for unblocked pornography. Filters often "over block" by simply blocking on keywords, which leads to the blocking of legitimate sites that mention, for example, breast cancer or the holocaust.

tunneling

The process of encapsulating packets within IP packets for the purpose of transporting the interior packets through many public intermediate systems. When reassembled at the remote end, the interior packets will appear to have transited only one router on the private networks.

content blocking

A security measure that blocks access to websites based on keywords contained in the content.

A more realistic and manageable approach is to simply tell users that their website visits are logged on the firewall and that they will be asked to justify browsing any suspicious sites. This will keep them from doing anything that violates your policy, allow broad access to legitimate sites, and won't require content-blocking subscriptions. You can often set up logs to include the amount of time a user spent on a specific website, so you can watch for inordinately long periods of random surfing and eliminate "false hits," when a pop-up window in a justifiable site opens up a web page on the seedy side of the Internet.

Selecting a Firewall

There are hundreds of firewalls on the market, running on numerous different platforms. Selecting a firewall that matches your security requirements could take quite a bit of time.

Fortunately for you, the firewall market has shaken out a lot of competitors lately. Among the remaining firewalls, you need only seriously consider the following, which are among the strongest in the field and remain reasonably inexpensive. They are listed here in order of ease of use (easiest to hardest) and security (increasingly strong) order:

SonicWALL Firewalls The easiest to use and least expensive device-based firewalls. They do not include proxy-level filtering, but they can forward traffic to a proxy. Very similar to Firewall-1 in security and configuration, with a web interface.

WatchGuard Firebox Series Strong security in a low-priced device-based firewall. These are the only true devices (no hard disk drive) that actually proxy the protocols. Based on Linux and the original open-source Firewall Toolkit (FWTK) underneath, with an administrative application that runs only in Windows.

Symantec VelociRaptor Security Device A device (with hard disks) version of the strong Raptor security proxy. These are Sun RaQ computers preconfigured with Raptor Firewall.

Fortinet Fortigate Antivirus Firewalls Fortigate firewalls are very comparable to Sonicwall devices in their overall feature set, but they excel at high-speed antivirus, content blocking, and intrusion detection and blocking. These firewalls feature a custom application-specific microprocessor that uses signature-based detection of Application layer content that provides most of the features of a proxy server at the speed of a packet filter.

Cisco PIX Firewall A firewall developed entirely from its own original sources by Cisco, PIX is the leader in high-speed firewalling and should be considered any time firewalling circuits faster than 10 Mb/s are required. While other firewalls may have 100Mb/s ports, they don't really firewall at 100Mb/s. High-end PIX firewalls can, and are used by ISPs and larger dot-coms to handle their high-speed firewalling requirements.

There's no reason to select a firewall just because it runs on the same operating system as the rest of your network. Most firewalls that run on operating systems are significantly less secure than device-based firewalls because they rely on the operating system to withstand denial of service attacks at the lower layers and because other insecure services may be running on the operating system.

The majority of firewalls are configured by creating a specific policy called a rule base, which typically lists pass/fail rules for specific protocols and ports. Usually, these rules are searched in top-down order, and the final order in the rule base is a "deny all" rule.

NOTE

Once you've selected a firewall, configuration depends entirely upon the firewall you've selected. You need to make yourself an expert on that specific firewall. This isn't particularly difficult anymore, and there's little reason to worry about learning other firewalls once you've selected one.

Terms to Know

Application-layer proxies	proxy server
border gateways	source routing
circuit layer switches	stateful inspection
content blocking	stateless packet filters
demilitarized zone	transparent
firewalls	tunneling
Network Address Translation	virtual private networking
packet filters	virus scanning

Review Questions

1. Firewalls are derived from what type of network component?
2. What is the most important border security measure?
3. Why is it important that every firewall on your network have the same security policy applied?
4. What is a demilitarized zone?
5. Why is it important to deny by default rather than simply block dangerous protocols?
6. What fundamental firewall function was developed first?
7. Why was Network Address Translation originally developed?
8. Why can't hackers attack computers inside a network address translator directly?
9. How do proxies block malformed TCP/IP packet attacks?